NeuroShield API

Объяснимая AI-платформа оценки риска мошенничества в переводах

Detect risk. Understand behavior. Protect every transaction.



Работающий MVP: API + дашборд + ML-эксперимент

Исследовательский прототип · синтетические данные · не подключён к банкам

Почему правил уже недостаточно



Ложные тревоги

Чтобы ловить больше, правила ужесточают — и под проверку попадают путешественники, крупные покупки, новые телефоны.



Клиент переводит сам

При социальной инженерии пароль верный и устройство своё. Для правил это обычный перевод — подозрителен только контекст.



Сети мулов

Каждый счёт по отдельности выглядит нормально. Видна только структура: деньги от многих людей и сразу дальше.



Нет объяснений

Аналитик видит «сработало правило R4», но не понимает, что изменилось в поведении клиента и почему это опасно.

Задача: оценивать риск, объяснять факторы и выбирать соразмерную проверку — а не просто блокировать.

Baseline: 8 явных правил, включая чёрный список

Правило	Баллы	Условие
R1	2	Amount >= 250,000
R2	1	New recipient and amount >= 60,000
R3	2	3 or more transactions in the last hour
R4	1	New device and amount >= 50,000
R5	1	Unusual location on an international transfer
R6	1	Night time (00-05) and amount >= 50,000
R7	1	Amount > 3 std above customer's usual
R8	2	Recipient is on the confirmed-fraud report list

Флаг при ≥ 2 баллах. Всё сработавшее идёт на ручную проверку.

66,8%
ловит мошенничества (recall)

4,78%
честных переводов — ложная тревога

22,5%
алертов — действительно мошенничество

41%
переводов мулов замечено

68,7%
крупных честных покупок помечены как подозрительные

Тестовый период синтетического набора: 13 909 переводов, 283 мошеннических.

Решение: 4 сигнала → модель → соразмерное действие

Транзакция

сумма vs норма клиента, время, скорость, новый получатель, устройство

Поведение

паузы, исправления, ритм набора — относительно своей нормы, только с согласия

Граф переводов

fan-in, быстрая пересылка, связь с подтверждёнными жалобами

Социальная инженерия

звонок во время сессии, ответ «меня попросили» — минимум 2 сигнала

Гибридная модель

градиентный бустинг совмещает сигналы → риск 0–100 + объяснение

LOW — **Разрешить**

без вмешательства

MEDIUM — **Step-up**

перепроверить получателя, предупреждение о мошенничестве

HIGH — **Проверка**

аналитик; временное удержание — только по политике банка

Защитное правило: одно лишь необычное поведение никогда не ведёт к удержанию перевода.

Техническая архитектура

Дашборд

React + TypeScript, 8 страниц

Внешний сервис

REST API v1, Swagger

Защита и валидация

лимит тела, rate limit, CSP, request-id; Pydantic: лишние поля и диапазоны отклоняются

Признаки

features.py — один код для обучения и API; паритет проверяется тестом

Модель

4 компонента (поведение, граф, соц. инженерия, репутация) → HistGradientBoosting

Политика

пороги из validation; объяснение окклюзией; отчёт аналитика

SQLite: решения · аудит · настройки

только псевдонимные ID, без тел запросов в логах

Graph Engine (NetworkX)

fan-in, цепочки пересылки, общие получатели

Офлайн-контур ML

генератор (seed 42) → 6 систем, разбиение по времени → model.joblib, policy.json, experiments/results

13+
REST-эндпоинтов

45
автотестов

8
страниц UI

Каждый компонент добавляет качество

Поведение относительно своей нормы

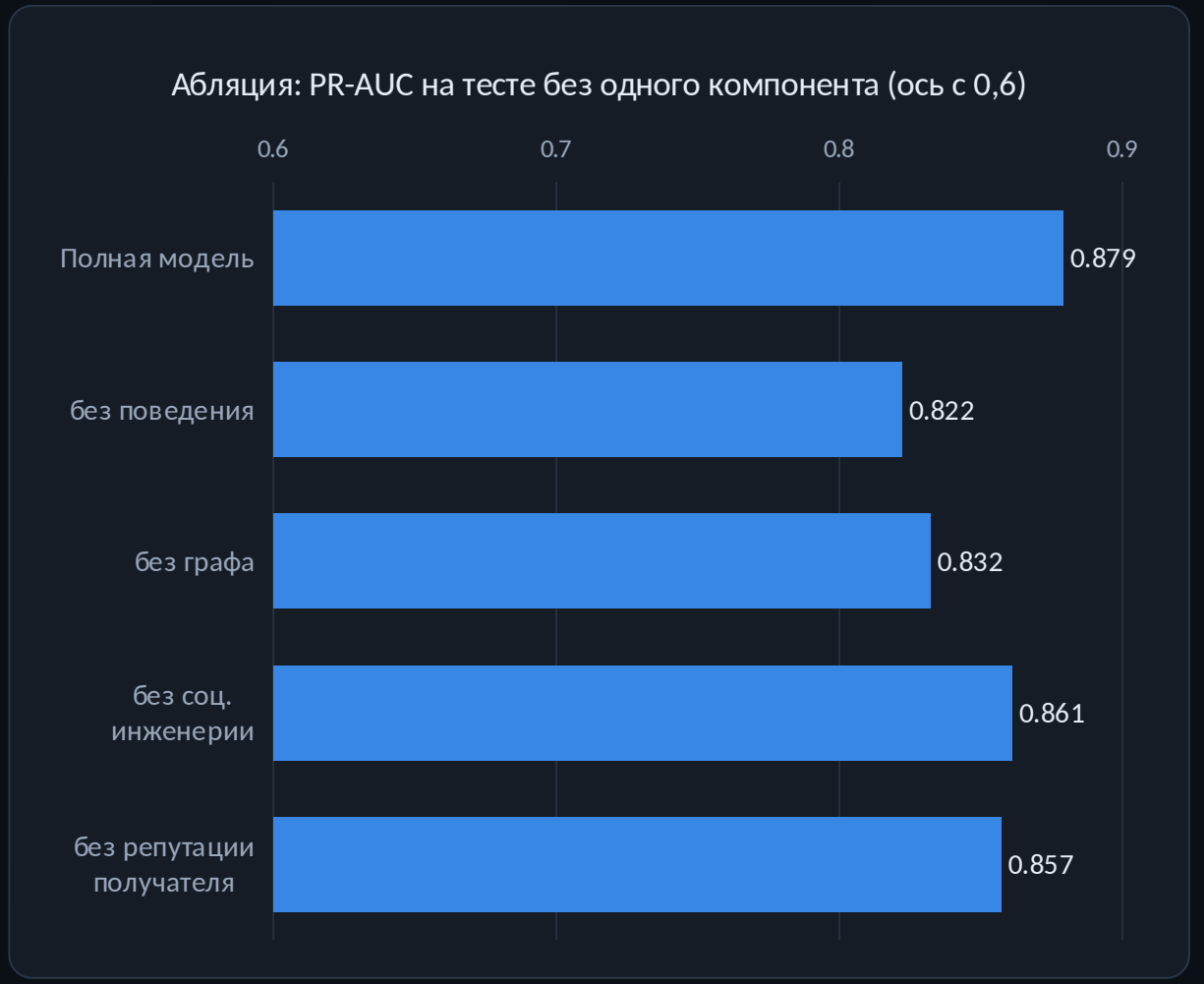
Отдельно ритм набора («другой человек?») и колебания («давление?»). Без согласия компонент выключен и ничего не додумывает.

Граф без заглядывания в будущее

Признаки только из прошлых переводов; жалобы приходят с задержкой 6–120 ч, поэтому метка не просачивается.

Социальная инженерия

Нужны минимум 2 независимых сигнала; один сигнал ограничен 45 баллами из 100.



Live demo: обычный перевод против социальной инженерии



A: 0,01 · LOW

перевод сестре 25 000 ₸, всё как обычно → разрешить

B: 97,2 · HIGH

450 000 ₸ новому счёту во время звонка, «меня попросили» → проверка

6 / 6

проверок пройдено: путешествие, новый телефон, крупная покупка — не HIGH

Сценарии идут через настоящий backend: валидация → признаки → модель → политика → объяснение. Синтетический клиент, реальный стресс не определяется.

Методика: без утечек, пороги до теста



90 дней синтетической истории банка · 3 000 клиентов · 145 тыс. операций · seed 42

Мошенничество 3 типов

захват аккаунта, социальная инженерия, сети мулов (пересылка)

9 типов «честного, но необычного»

путешествия, новый телефон, крупные покупки, смена привычек, переводы новым счетам, без телеметрии…

Защита от утечек

признаки только из прошлого; жалобы с задержкой 6–120 ч; модель и пороги — только по validation; test — один раз

6 систем

правила · LR и бустинг на транзакциях · LR, случайный лес и бустинг на гибридных признаках

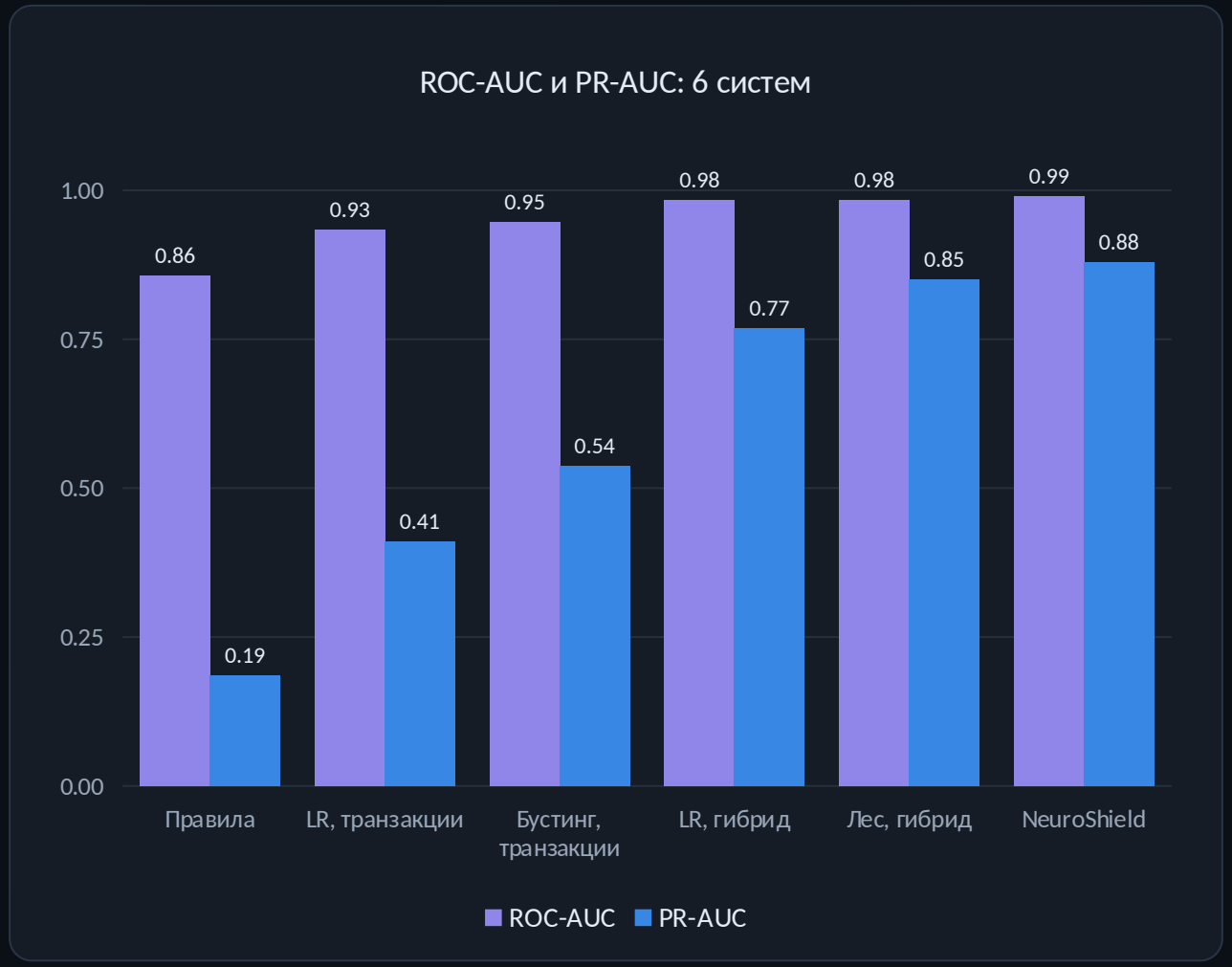
Устойчивость

повтор на 2 других seed и 3 «жёстких» вариантах данных; 95% CI бутстрэпом

Найден и исправлен баг

окно «транзакций за 24 ч» считало 24 дня — всё пересчитано после исправления

Результаты на тесте (синтетика)



4,78% → 0,07%

ложных тревог при равном recall: в 65 раз меньше

0,990

ROC-AUC, 95% CI 0,985–0,994; цель 0,94

85,9%

мошенничества → step-up при FPR 1,04%

91,6%

точность уровня HIGH (precision)

15,7 мс

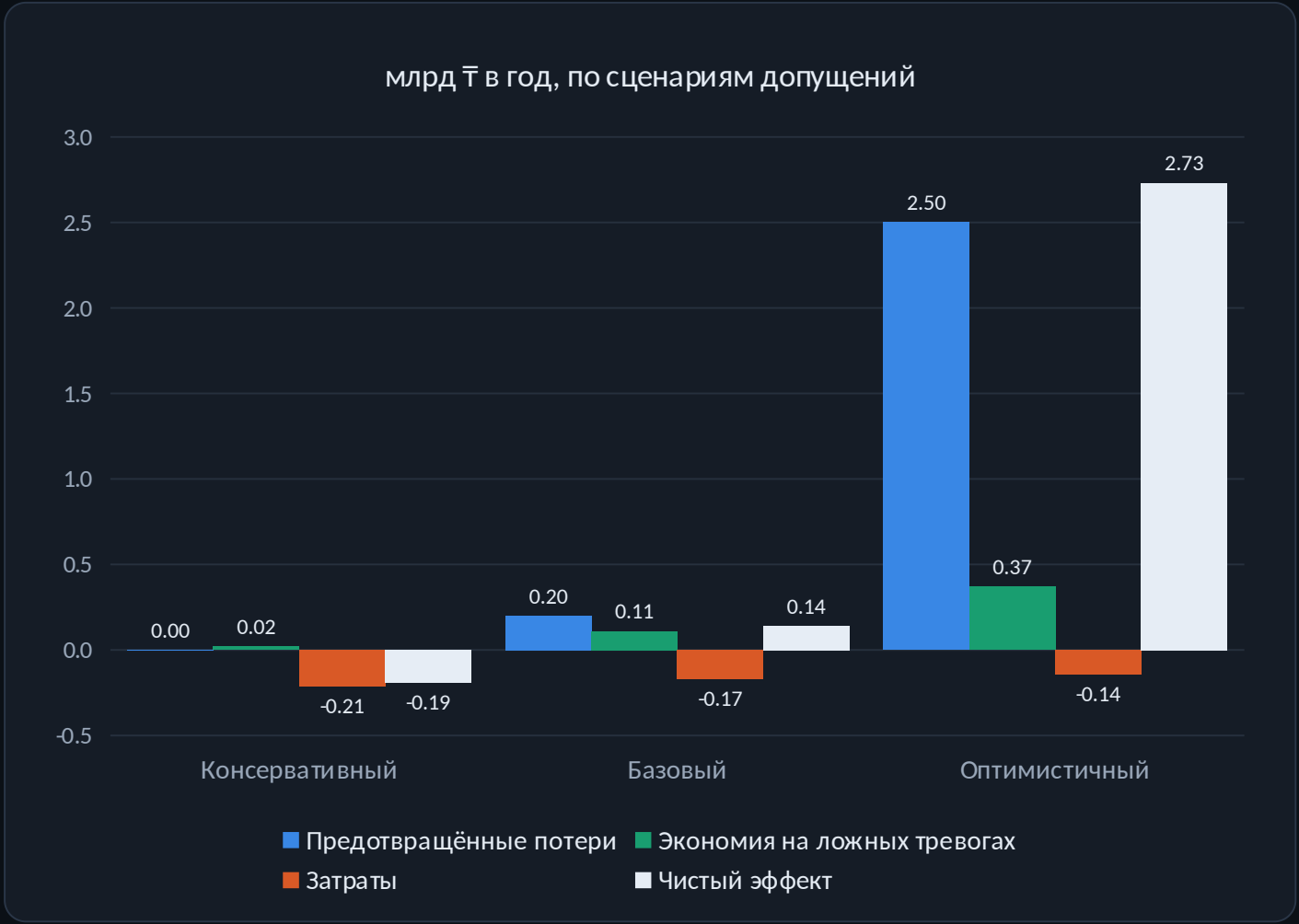
p95 HTTP-запроса; модель 6,1 мс; цель < 50

0,81–0,88

PR-AUC на других seed и жёстких данных

Синтетические данные: результаты показывают работоспособность подхода, а не эффективность в реальном банке.

Бизнес-кейс: окупается при достаточном объёме



0,14 млрд ₸

чистый эффект в год, базовый сценарий (50 млн переводов)

-0,19 млрд ₸

консервативный сценарий: малый объём — проект не окупается

≥ 27 млн

переводов в год для безубыточности; или снижение FPR ≥ 51,5%, или +4,3 п.п. recall

Параметры банка — допущения. Снижение FPR в сценариях 20–60%, а не синтетические 98,5%.

Безопасность, приватность и честные ограничения

Что сделано

- Валидация, лимиты тела и пакета, rate limit, CSP, аудит каждого решения
- Нет имён, карт, переписки, звонков — только псевдонимные ID и агрегаты
- Поведение только с согласия; нет данных — так и пишем, не додумываем
- Удержание — рекомендация; одно поведение не даёт HIGH

Проверено и что осталось

- **Синтетические данные**
  → повтор на исторических данных банка (этап 1)
- **Счета < 30 дней: ложные тревоги 9,0% (правила 2,1%)**
  → опция отдельного порога: 1,6%, но recall здесь 96% → 90%
- **Хитрый мошенник: −2,5…12,4 п.п. за 1 сигнал**
  → обучение на трюках не обобщается → нужны новые сигналы
- **Нагрузка: 91 → 169 запр./с (1 → 2 процесса)**
  → задержка 44 мс у 2 процессов устранена; Docker — в CI

Не сертифицировано (PCI DSS, ISO 27001). Для реального банка нужны юридическая проверка, DPIA, security review и согласие клиентов.

Дорожная карта и вывод

1

Данные и baseline

повтор эксперимента на истории банка против его реальных правил

2

Shadow mode

оценка живого трафика без влияния на платежи, 3 мес.

3

Контролируемый пилот

step-up для 5% клиентов, A/B против контроля

4

Постепенный rollout

security review, нагрузка, регулятор

5

Мониторинг

дрейф признаков, переобучение по порогам



Вывод

Работающий объяснимый прототип: API, дашборд, 45 тестов, воспроизводимый эксперимент, стресс-тесты. На синтетике — ROC-AUC 0,990 и в 65 раз меньше ложных тревог, чем у правил. Мы не говорим, что система готова для банка — мы показываем, как это проверить и по каким критериям идти дальше.